Banco de Perguntas da Banca

Startup XYZ — Gestão de Documentos para IA | Respostas curtas, com quem responde

Equipe: Athos, Jhonatan, Gabriel, Lucas, Rafael

A banca pode direcionar qualquer pergunta a qualquer integrante. O nome em laranja indica quem responde primeiro; os outros complementam só se faltar algo. Responda em duas ou três frases e pare: a banca pergunta de novo se quiser mais.

Arquitetura

Por que serverless e não EC2? Jhonatan

O volume é ~1,2 documento por minuto e irregular. Uma EC2 ficaria ociosa quase o tempo todo e ainda exigiria escalar, aplicar patches e balancear. Com Lambda e API Gateway pagamos por requisição e não há servidor para cair ou dimensionar.

Por que API Gateway e não Lambda Function URL? Jhonatan

A Function URL só autentica com IAM ou fica aberta. O API Gateway tem authorizer JWT nativo do Cognito, limite de requisições por rota, domínio próprio e log de acesso. Barrar token inválido antes da Lambda também economiza execução.

Por que HTTP API e não REST API? Jhonatan

A HTTP API é mais barata (US$ 1,59 por milhão em São Paulo) e já tem authorizer JWT. A REST API só faria sentido se precisássemos de WAF direto no Gateway ou de planos de uso por cliente.

Por que S3 e não EFS, RDS ou DynamoDB para os arquivos? Jhonatan

Os documentos são gravados uma vez e lidos poucas vezes. O S3 tem 11 noves de durabilidade, classes de custo para arquivamento e URL pré-assinada. EFS é sistema de arquivos compartilhado, mais caro e sem classe de arquivo profundo; banco de dados não é lugar de binário.

Por que não checar a permissão só no código? Lucas

Porque código tem bug. Um erro de autorização (IDOR) deixaria o usuário A ler o B. Com a credencial do STS restrita à pasta, mesmo com bug a AWS nega. Mostramos isso ao vivo desligando a checagem.

Por que um bucket com uma pasta por cliente e não um bucket por cliente? Jhonatan

A AWS permite até 1 milhão de buckets, então não é limite. É operação: cada bucket seria mais uma política, um ciclo de vida e uma configuração de chave. Com um bucket e credencial por pasta temos o mesmo isolamento, uma configuração só e o histórico reunido para a IA.

Como o usuário lista os documentos dele? Lucas

A Lambda lista com a mesma credencial restrita, e a session policy só permite ListBucket com a condição s3:prefix igual à pasta dele. É exatamente aqui que essa condition key vale. Para busca por nome ou status, a evolução é uma tabela de metadados no DynamoDB.

Onde fica o nome original do arquivo? Jhonatan

O servidor gera o nome como UUID, para evitar colisão e nomes maliciosos. O nome original pode ir como metadado do objeto ou numa tabela de metadados.

Segurança

E se a URL pré-assinada vazar? Gabriel

Ela vale como um ingresso: quem tiver pode usar. Por isso vale 15 minutos para upload e 5 para download, para um único objeto, só por HTTPS. Se vazar, a aba Revogar sessões da role invalida na hora todas as URLs já assinadas. Tudo fica no CloudTrail.

Quem pode acessar os recursos? Gabriel

O usuário só alcança a própria pasta. A Lambda não tem acesso ao bucket: ela só pode assumir a role de acesso, e reduz essa role a uma pasta por pedido. Só a conta root consegue apagar uma versão de vez. O bucket é fechado ao público.

Por que não há VPC, subnets e Security Groups? Gabriel

Nenhum componente precisa de rede privada: não há banco nem servidor. Colocar a Lambda numa VPC adicionaria NAT Gateway (custo fixo) sem ganho. O controle está em IAM, na política do bucket, na exigência de TLS e no limite de requisições.

E ataque de negação de serviço? Gabriel

O AWS Shield Standard é automático. O API Gateway limita cada rota a 10 req/s com pico de 20 e responde 429 acima disso. Se precisar de regras por IP, colocamos WAF (via REST API ou CloudFront).

E se alguém enviar um arquivo malicioso? Gabriel

A URL de upload só aceita PDF, PNG e JPEG até 20 MB. No desenho, o GuardDuty escaneia cada objeto novo e marca com uma tag; o parâmetro EnforceMalwareScan faz o app ler só arquivos marcados como limpos. Na demo ele não aparece porque o plano gratuito da AWS bloqueia o GuardDuty.

Criptografia é exigência da LGPD? Gabriel

A LGPD pede medidas de segurança adequadas (art. 46), sem nomear tecnologia. Usamos KMS com chave própria porque dá controle da chave e registro de uso. Com Bucket Keys o KMS registra por bucket, então a auditoria por objeto vem do CloudTrail.

Vocês usaram a conta root? Gabriel

Na demo, sim. Em produção: MFA no root, acesso pelo IAM Identity Center e root só para emergência, que é inclusive quem pode apagar versões.

LGPD e negócio

'Nunca apagar' não conflita com o direito de exclusão (art. 18)? Athos

É regra de negócio, não trava técnica absoluta. Aplicação e administradores não conseguem apagar; a exclusão definitiva existe por um processo controlado com a conta root, registrado no CloudTrail. O contrato define o prazo de retenção.

Pode usar documento de cliente para treinar IA? Rafael

Só com base legal no contrato ou consentimento. Na evolução: Macie para achar dados pessoais, anonimização e treino num ambiente separado, sem acesso ao bucket de produção.

Por que não replicar para outra região? Gabriel

O Brasil tem uma região AWS. Replicar seria mandar dado pessoal para fora do país (transferência internacional, art. 33) e custaria ~US$ 7 por mês só de transferência (US$ 0,138/GB saindo de São Paulo), fora as gravações na outra região. Falha regional afeta acesso, não a durabilidade. Se um contrato exigir, é uma regra de replicação a mais.

Custos

Qual o recurso mais caro? Gabriel

O ano de documentos em S3 Standard (~US$ 24/mês), depois o GuardDuty (~US$ 20). No 3º ano o total fica em ~US$ 60/mês em São Paulo.

O que acontece com 10 vezes a demanda? Gabriel

O custo cresce proporcional, sem degrau: ~US$ 580/mês (6 TB em Standard, 18 TB em Deep Archive, GuardDuty para 500 mil uploads). Não entra servidor nem licença.

Como reduzir mais? Rafael

Standard-IA ou Intelligent-Tiering depois de 30 a 90 dias, se o acesso cair antes de um ano; Lambda em ARM (cerca de 20% mais barata); escanear só os tipos de arquivo que o parser abre.

Por que Deep Archive e não Glacier Instant Retrieval? Gabriel

Em São Paulo, Deep Archive custa US$ 0,0032/GB e Glacier Instant US$ 0,0083. Depois de um ano o acesso é raro. Se o treino de IA ler o histórico com frequência, trocamos a regra para Glacier Instant.

E objetos pequenos? Gabriel

Objetos com menos de 128 KB não mudam de classe por padrão, porque a taxa de transição não compensaria. Ficam em Standard, com custo irrelevante.

Por que não mostraram a Pricing Calculator? Gabriel

Calculamos com a AWS Price List oficial de São Paulo, item a item. Se a banca quiser, a mesma conta pode ser montada na calculadora.

Escalabilidade e recuperação

Existe gargalo? Gabriel

Só cotas de conta: concorrência da Lambda (1.000 por padrão), taxa de chamadas ao STS e ao KMS (Bucket Keys reduzem), ajustáveis com pedido. O S3 aguenta 3.500 gravações por segundo por prefixo, e cada usuário tem o seu.

O que acontece num pico? Gabriel

Acima de 10 req/s por rota a API responde 429 e o app tenta de novo com espera crescente. Como o arquivo vai direto ao S3, o pico não chega ao backend.

Quanto tempo para restaurar? Gabriel

Documento em Standard: imediato. Versão sobrescrita ou apagada: segundos, pelo versionamento. Documento em Deep Archive: até 12 horas (ou 48 h no modo mais barato). Infraestrutura inteira: ~2 minutos pelo CloudFormation.

E se a Lambda falhar? Lucas

O alarme de erros dispara, o app tenta de novo e nada se perde, porque o arquivo não passa pela Lambda. Se o erro for no código, a versão anterior é republicada pelo template.

Demonstração

Isso está rodando de verdade? Lucas

Sim, na conta do grupo em São Paulo, stack xyz-docs. O CloudTrail mostra cada credencial emitida e os logs da API mostram cada chamada, inclusive o 403 do ataque.

Por que o GuardDuty não aparece na demo? Lucas

O plano gratuito da AWS bloqueia o serviço. A arquitetura e o template já estão prontos para ele (parâmetro EnforceMalwareScan).

Outra pessoa consegue recriar o projeto? Rafael

Sim: o template CloudFormation cria os 26 recursos em ~2 minutos, e o README e o Manual da Demo explicam cada passo com prints.